



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2026-4681 PTC Windchill and FlexPLM Critical RCE Report

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-08-12
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | CVE-2026-4681 PTC Windchill and FlexPLM Critical RCE Report - CVE / Vulnerability Threat Intelligence Report

Published: 2026-08-12 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Key Judgments
3. Vulnerability Metadata
4. Affected Products
5. Source Review and Confidence
6. Technical Analysis
7. Attack Scenarios
8. Indicators of Compromise and Observable Patterns
9. Mitigation and Workarounds
10. Detection Engineering
 - 10.1. Detection Logic Summary
 - 10.2. Sigma: Suspicious CVE-2026-4681 Windchill/FlexPLM HTTP Patterns
 - 10.3. Sigma: PTC Windchill Filesystem IOC Artifacts
 - 10.4. YARA: CVE-2026-4681 Windchill Artifact Strings
 - 10.5. Suricata: Suspicious Windchill/FlexPLM Request Pattern
11. Threat Hunting
 - 11.1. Microsoft Defender KQL: HTTP Pattern Hunt
 - 11.2. Microsoft Defender KQL: Filesystem IOC Hunt
 - 11.3. Microsoft Defender KQL: Java/Tomcat Child Process Hunt
 - 11.4. Splunk SPL: Web Request Pattern Hunt
12. MITRE ATT&CK Mapping
13. Incident Response Guidance
14. Recommended Actions Summary
15. References

CVE-2026-4681 PTC Windchill and FlexPLM Critical RCE Report

1. Executive Summary

CVE-2026-4681 is a critical remote code execution vulnerability in PTC Windchill and PTC FlexPLM disclosed through PTC and CISA ICS advisory channels in March 2026. PTC describes the issue as exploitable through deserialization of untrusted data, and CISA ICSA-26-085-03 states that successful exploitation could allow an attacker to achieve remote code execution. PTC's March remediation center lists CVSS v3.1 10.0 and CVSS v4 9.3 severity.

This report should be read as the baseline March 2026 Windchill/FlexPLM RCE report. It is distinct from CVE-2026-12569, the later June 2026 Windchill/FlexPLM RCE issue that CISA added to KEV and that public reporting associates with Cl0p exploitation. CVE-2026-4681 did not have confirmed PTC-customer exploitation in PTC's March advisory text captured for this report, but the technical conditions are still urgent: remotely reachable Java deserialization RCE against high-value PLM systems can lead to server takeover, webshell deployment, product-data theft, lateral movement, and operational disruption.

Lost Boys Cyber assesses CVE-2026-4681 as a critical exposure-management priority for manufacturing, aerospace, automotive, defense-industrial, retail/apparel, and any organization using Windchill/FlexPLM to store product lifecycle, engineering, supplier, or regulated design data. Defenders should apply vendor patches or emergency web-server mitigations, remove public exposure, hunt for PTC-provided filesystem IOCs, review HTTP patterns such as `run?p=`, `.jsp?p=`, `run?c=`, and `.jsp?c=`, and treat any suspected exploitation as a business-data incident rather than a simple web-server alert.

2. Key Judgments

Judgment	Assessment	Confidence
Severity	Critical; PTC listed CVSS v3.1 10.0 and CVSS v4 9.3, while CISA lists successful exploitation impact as RCE.	High
Affected technology	Multiple Windchill PDMLink and FlexPLM release lines are affected, including 11.x, 12.x, and 13.x versions listed by CISA.	High
Exploitation status	PTC's March advisory language captured for this report says there was no evidence of confirmed exploitation affecting PTC customers at that time.	Medium-High
Operational risk	Publicly accessible Windchill/FlexPLM instances are highest risk because exploitation can reach PLM application tiers without normal workstation telemetry.	High
Detection approach	Combine web request pattern analytics, filesystem IOC review, application-server child-process hunting, and PLM data-access anomaly review.	High

3. Vulnerability Metadata

Field	Value
CVE	CVE-2026-4681
Vendor / Products	PTC Windchill Product Lifecycle Management / Windchill

	PDMLink and PTC FlexPLM
Weakness	Improper control of code generation / code injection; unsafe deserialization of untrusted data
CVSS	PTC March advisory: CVSS v3.1 10.0 Critical; CVSS v4 9.3 Critical
CISA Advisory	ICSA-26-085-03, released 2026-03-26
Critical Infrastructure Context	CISA lists Critical Manufacturing, worldwide deployment, vendor headquarters United States
Exploitation Status	No confirmed PTC-customer exploitation stated in captured March PTC advisory text; still critical due to RCE and public exposure risk
Primary Defender Objective	Patch/mitigate immediately, remove internet exposure, hunt for source-reported filesystem and HTTP indicators

4. Affected Products

CISA ICSA-26-085-03 lists the following affected versions for CVE-2026-4681:

Product Family	Affected Versions Listed by CISA
Windchill PDMLink	11.0 M030, 11.1 M020, 11.2.1.0, 12.0.2.0, 12.1.2.0, 13.0.2.0, 13.1.0.0, 13.1.1.0, 13.1.2.0, 13.1.3.0
FlexPLM	11.0 M030, 11.1 M020, 11.2.1.0, 12.0.0.0, 12.0.2.0, 12.0.3.0, 12.1.2.0, 12.1.3.0, 13.0.2.0, 13.0.3.0

Asset owners should validate the exact release, CPS level, and patch/hotfix status against the current PTC remediation center. Do not rely on product family alone; Windchill/FlexPLM deployments are often customized, integrated with SSO, and deployed behind reverse proxies that can obscure the true application version from external scanners.

5. Source Review and Confidence

Source	Contribution	Confidence
PTC March 2026 Windchill/FlexPLM Critical Vulnerability Response Center	Vendor statement, severity, affected releases, mitigation direction, filesystem IOC patterns.	High
CISA ICSA-26-085-03	Independent ICS advisory, affected-product list, critical manufacturing context, CVSS v3 10 listing.	High
NVD CVE-2026-4681	Baseline CVE identity and description, marked awaiting enrichment in search result context.	Medium-High
GitHub Advisory Database / commercial vulnerability databases	Additional public enrichment and reference tracking.	Medium

6. Technical Analysis

CVE-2026-4681 is described as remote code execution through deserialization of untrusted data. In Java enterprise systems, unsafe deserialization vulnerabilities can allow attackers to send crafted serialized objects or request payloads that cause server-side code execution when processed by vulnerable libraries or application handlers. The practical defender concern is not simply that code execution is possible; it is that the execution occurs in the trust context of a high-value PLM application server.

Windchill and FlexPLM environments typically sit close to sensitive product lifecycle records, engineering designs, material data, supplier documents, workflows, and administrative integrations. A successful exploit can therefore create both technical and business-impact paths: webshell placement, command execution, credential exposure from application configuration, PLM data export, tampering with workflows, and pivoting into adjacent engineering or manufacturing systems.

PTC's March advisory content captured for this report includes suspicious HTTP request patterns using `run?p=`, `.jsp?p=`, `run?c=`, and `.jsp?c=`; a user-agent string that should only be treated as meaningful when correlated with suspicious request paths; filesystem IOCs including `GW.class` and `payload.bin`; and randomized JSP naming using `dpr_<8-hex-digits>.jsp`.

7. Attack Scenarios

Scenario	Attacker Objective	Defender Priority
Public Windchill/FlexPLM instance	Send crafted deserialization payloads to gain server-side execution.	Remove internet exposure, apply PTC patch/mitigation, inspect edge logs.
Partner-accessible deployment	Abuse supplier/partner path that bypasses broader internet scanning controls.	Validate partner ingress, inspect WAF and IdP logs, narrow allowlists.
Post-exploitation webshell	Persist through JSP/class artifacts after initial RCE.	Search for <code>GW.class</code> , <code>payload.bin</code> , <code>dpr-style</code> JSP files, and unexpected webroot changes.
Data-theft preparation	Enumerate PLM documents, design files, BOMs, and supplier attachments.	Review application object access, exports, archive creation, and large downloads.
Lateral movement	Harvest application credentials or service account tokens.	Rotate secrets, inspect config access, review app service-account behavior.

8. Indicators of Compromise and Observable Patterns

The sidecar `iocs.csv` preserves PTC source-reported hashes and durable behavioral patterns. Treat hash matches as high-priority evidence, but remember that deserialization exploit payloads and webshell filenames can be trivially changed. Behavioral and filesystem patterns are therefore essential.

Indicator Class	Values / Pattern	Defensive Use
Filesystem artifacts	<code>GW.class</code> , <code>payload.bin</code>	PTC states presence of <code>GW.class</code> or <code>dpr-style</code> JSP on a Windchill server indicates weaponization before RCE.
Random JSP naming	<code>dpr_<8-hex-digits>.jsp</code>	Search web roots and Windchill application paths for unexpected randomized JSPs.
Suspicious HTTP patterns	<code>run?p=</code> , <code>.jsp?p=</code> , <code>run?c=</code> , <code>.jsp?c=</code>	Correlate with WAF/proxy logs, especially against Windchill/FlexPLM hosts.
User-Agent context	Mozilla/5.0 ... Chrome/137.0.0.0 Safari/537.36	Use only when observed together with suspicious request patterns; do not block by user-agent alone.

SHA-256 hashes	C818011CAFF82272F8CC50B670304748 984350485383EBAD5206D507A4B44FF1 , plus additional hashes in iocs.csv	Triage source-reported artifacts and match against EDR/file inventory.
----------------	--	--

9. Mitigation and Workarounds

Priority	Owner	Action
Critical	Application owners	Apply PTC security patches or current vendor remediation guidance for every affected Windchill/FlexPLM instance.
Critical	Network/security engineering	Protect publicly accessible Windchill systems; place direct access behind VPN/ZTNA/WAF controls and strict partner allowlists.
Critical	Web/server admins	Apply PTC-provided Apache or IIS HTTP Server configuration workaround steps where official patches are not yet applied or where vendor guidance requires layered mitigation.
High	Detection engineering	Deploy request-pattern, filesystem, child-process, and data-access hunts from this report.
High	Incident response	If exposure existed before mitigation, preserve web, WAF, reverse-proxy, Tomcat, Windchill, and endpoint telemetry for retroactive investigation.

10. Detection Engineering

10.1. Detection Logic Summary

Signal	Telemetry Source	Goal
run?p= / .jsp?p= / run?c= / .jsp?c= request patterns	WAF, reverse proxy, web server logs	Identify exploitation attempts and post-exploitation command traffic.
GW.class, payload.bin, dpr_*.jsp	EDR and filesystem inventory	Identify weaponization artifacts.
Java/Tomcat spawning shell or download utilities	EDR process telemetry	Identify server-side command execution.
Large PLM data exports or archive creation	Application logs and endpoint telemetry	Identify data-theft preparation.

10.2. Sigma: Suspicious CVE-2026-4681 Windchill/FlexPLM HTTP Patterns

```

title: Suspicious PTC Windchill FlexPLM CVE-2026-4681 HTTP Pattern
id: lbc-cve-2026-4681-windchill-flexplm-http-pattern
status: experimental
description: Detects suspicious request patterns PTC advised defenders to correlate for CVE-2026-4681 activity.
logsource:
  category: webserver
detection:
  selection_uri:

```

```

cs-uri|contains:
- 'run?p='
- '.jsp?p='
- 'run?c='
- '.jsp?c='
condition: selection_uri
level: high

```

10.3. Sigma: PTC Windchill Filesystem IOC Artifacts

```

title: PTC Windchill FlexPLM CVE-2026-4681 Filesystem IOC Artifact
id: lbc-cve-2026-4681-windchill-filesystem-ioc
status: experimental
description: Detects creation of filesystem artifacts reported by PTC for CVE-2026-4681 investigations.
logsource:
  category: file_event
detection:
  selection_names:
    TargetFilename|contains:
      - 'GW.class'
      - 'payload.bin'
  selection_dpr:
    TargetFilename|re: 'dpr_[0-9a-fA-F]{8}\.jsp$'
  condition: selection_names or selection_dpr
level: critical

```

10.4. YARA: CVE-2026-4681 Windchill Artifact Strings

```

rule LBC_CVE_2026_4681_Windchill_FlexPLM_Artifact_Strings {
  strings:
    $f1 = "GW.class" ascii wide
    $f2 = "payload.bin" ascii wide
    $p1 = "run?p=" ascii wide
    $p2 = ".jsp?p=" ascii wide
    $p3 = "run?c=" ascii wide
    $p4 = ".jsp?c=" ascii wide
    $dpr = "dpr_" ascii wide
  condition:
    2 of them
}

```

10.5. Suricata: Suspicious Windchill/FlexPLM Request Pattern

```

alert http any any -> $HOME_NET any (msg:"LBC CVE-2026-4681 suspicious Windchill/FlexPLM command-style request pattern"; flow:to_server,established; http.uri;
pcr:'/(run?p=|\.jsp?p=|run?c=|\.jsp?c=)/Ui'; classtype:web-application-attack; sid:4260468101;
rev:1; metadata:tlp clear, cve CVE_2026_4681;)

```

11. Threat Hunting

11.1. Microsoft Defender KQL: HTTP Pattern Hunt

```

DeviceNetworkEvents
| where Timestamp > ago(45d)
| where RemoteUrl has_any ("run?p=", ".jsp?p=", "run?c=", ".jsp?c=", "Windchill", "FlexPLM")
| project Timestamp, DeviceName, RemoteIP, RemoteUrl, InitiatingProcessFileName,
InitiatingProcessCommandLine, AdditionalFields
| order by Timestamp desc

```

11.2. Microsoft Defender KQL: Filesystem IOC Hunt

```

DeviceFileEvents
| where Timestamp > ago(45d)
| where FileName in~ ("GW.class", "payload.bin")
  or FileName matches regex @"dpr_[0-9a-fA-F]{8}\.jsp"
| project Timestamp, DeviceName, FolderPath, FileName, SHA256, InitiatingProcessFileName,
InitiatingProcessCommandLine
| order by Timestamp desc

```

11.3. Microsoft Defender KQL: Java/Tomcat Child Process Hunt

```
DeviceProcessEvents
| where Timestamp > ago(45d)
| where InitiatingProcessFileName in~ ("java.exe", "java", "tomcat.exe", "tomcat", "httpd.exe",
"w3wp.exe")
| where ProcessCommandLine has_any ("cmd.exe", "powershell", "bash", "sh -c", "curl", "wget",
"certutil", "whoami", "id", "net user")
| project Timestamp, DeviceName, AccountName, InitiatingProcessFileName, InitiatingProcessCommandLine,
FileName, ProcessCommandLine
| order by Timestamp desc
```

11.4. Splunk SPL: Web Request Pattern Hunt

```
(index=web OR index=waf OR sourcetype=access_combined)
(uri="*run?p=" OR uri="*.jsp?p=" OR uri="*run?c=" OR uri="*.jsp?c=" OR uri="*Windchill*" OR
uri="*FlexPLM*")
| stats count min(_time) as first_seen max(_time) as last_seen values(uri) as uris values(useragent) as
useragents by src_ip dest host status
| sort - count
```

12. MITRE ATT&CK Mapping

Technique	Name	Rationale
T1190	Exploit Public-Facing Application	RCE against externally reachable Windchill/FlexPLM surfaces.
T1505.003	Server Software Component: Web Shell	Random JSP and class artifacts indicate web/app-server persistence risk.
T1059	Command and Scripting Interpreter	Command-style request parameters and app-server child processes indicate execution.
T1105	Ingress Tool Transfer	Payload.bin/class artifacts and potential follow-on tooling.
T1083	File and Directory Discovery	Attackers likely enumerate PLM repositories before theft or impact.
T1005	Data from Local System	PLM systems hold sensitive business and engineering data.
T1041	Exfiltration Over C2 Channel	Compromised PLM data may be transferred to external infrastructure.

13. Incident Response Guidance

1. Scope every Windchill/FlexPLM instance, including disaster recovery, test, partner, and hosted environments.
2. Preserve WAF, reverse-proxy, web server, Tomcat, Windchill, endpoint, and identity logs before rotation.
3. Search for PTC-provided hashes and filesystem artifacts from iocs.csv.
4. Hunt HTTP request patterns and Java/Tomcat child-process activity.
5. If any match is confirmed, isolate the application tier, collect forensic images or snapshots, rotate secrets, and assess PLM data access/export history.
6. Rebuild from clean media when webshells or unauthorized code artifacts are confirmed.

14. Recommended Actions Summary

Priority	Action	Expected Outcome
Critical	Patch or apply PTC emergency workaround on all affected versions.	Removes primary RCE path.
Critical	Remove direct public exposure and enforce VPN/ZTNA/WAF restrictions.	Reduces exploitability during patch windows.
High	Deploy detections/hunts for HTTP patterns, filesystem artifacts, and app-server child processes.	Finds attempts or compromise.
High	Review sensitive PLM data access and exports.	Identifies business impact.
Medium	Add PLM systems to crown-jewel monitoring and quarterly incident playbooks.	Improves future response speed.

15. References

- [1] PTC Windchill & FlexPLM Critical Vulnerability Updates and Remediation, March 2026. <https://www.ptc.com/en/about/trust-center/advisory-center/active-advisories/windchill-flexplm-critical-vulnerability>
- [2] CISA ICSA-26-085-03: PTC Windchill Product Lifecycle Management. <https://www.cisa.gov/news-events/ics-advisories/icsa-26-085-03>
- [3] NVD CVE-2026-4681. <https://nvd.nist.gov/vuln/detail/CVE-2026-4681>
- [4] GitHub Advisory Database GHSA-jfrx-fmg3-3p8m. <https://github.com/advisories/ghsa-jfrx-fmg3-3p8m>
- [5] Tenable CVE-2026-4681. <https://www.tenable.com/cve/CVE-2026-4681>